

Cuestionario Riesgo Operacional

Instrucciones de diligenciamiento:

- Seleccionar la respuesta en la columna "Respuesta"
- Siempre se debe dar una justificación a la respuesta seleccionada en la columna "Detalle".

- Para las preguntas cuya alternativa de respuesta es "Abierta o no aplica":
 - Seleccione "No aplica" en el campo "Respuesta" en caso de no contar con lo que indica la pregunta.
 - Si cuenta con lo indicado en la pregunta, deberá proporcionar una respuesta en el campo "Detalle".



INFORMACIÓN BÁSICA PROVEEDOR	
Razón Social Proveedor:	INTIZA S.A.
NIT/RUC:	216662830015
Alcance Servicio Prestado al Banco:	Desarrollo de software de cobanzas
Registra la URL principal del servicio que el proveedor presta al	www.intiza.com
Fecha Diligenciamiento Cuestionario (DD/MM/AAAA):	19/12/2025
Persona Responsable Diligenciamiento Cuestionario:	
Email Persona Responsable Diligenciamiento Cuestionario:	

No.	PREGUNTA	ALTERNATIVAS DE RESPUESTA	RESPUESTA	DETALLE
CATEGORÍA: General				
1	¿Cuenta con sistemas o esquemas de seguridad y monitoreo para la ejecución de actividades de los colaboradores dentro de sus sedes?	a) No tiene b) Mecanismos manuales (supervisión por un co	B	Nuestra política aplica controles de acceso locales para todo el personal y los recursos informáticos son sujetos a revisión y evaluación. El acceso a nuestras oficinas cuenta con un sistema de huellas digitales con el que accede cada colaborador y el edificio cuenta con monitoreo en cámaras, alarmas, entre otros sistemas de seguridad física. El mecanismo es manual en el caso de los ingresos excepcionales.
2	¿Existe una adecuada segregación de funciones y aprobaciones en la ejecución de actividades dentro del proceso de la compañía?	a) No tiene b) Se aplica la segregación de funciones, sin em	D	Los privilegios se asignan por rol, asegurando que el personal no altere programas ni datos fuera de sus responsabilidades. Implementamos procesos formales de solicitud y autorización para todos los accesos.
3	¿Como garantiza la correcta desvinculación de los empleados que participan en el servicio prestado a Bam?	a) Realiza la desvinculación bajo la norma establecida, cumpl	C	Garantizamos una desvinculación segura y oportuna. Todos los accesos físicos e informáticos de un colaborador se deshabilitan el mismo día de su desvinculación. Un control automático revisa estos accesos cada hora.
4	¿Cuáles son los métodos utilizados para la selección del personal a contratar que participará en el servicio brindado a Bam?	Abierta o no aplica	No aplica	Contamos con un proceso marco global para la selección objetiva e imparcial de colaboradores. Esto incluye la solicitud de referencias, evaluaciones psicotécnicas y exámenes médicos preocupacionales, según el rol. Para cargos sensibles, solicitamos certificados de buena conducta y declaraciones juradas de salud. Aseguramos la idoneidad del personal. Adjunto nuestra norma: NO-RH-01 Contratación de Recursos Humanos_v2.1_2025-04-30.pdf
5	¿Posee un proceso y responsable definido para garantizar la inscripción y actualización de las licencias conforme a lo establecido en la legislación y normativa legal vigente?	Abierta o no aplica	No aplica	Contamos con un procedimiento formal que garantiza la inscripción y gestión de licencias de software. Este proceso define roles claros para la solicitud, aprobación y registro en nuestro "Registro de SW", asegurando su control y cumplimiento continuo. Adjunto: NO-SI-24 Gestión de Software_v2.1_2024-11-12.pdf
CATEGORÍA: Información Digital				
1	¿Cuenta con un control DLP (Data Loss Prevención)?	a) Sib) No	A	Disponemos de un conjunto de software especializado que cumple esta función, asegurando la protección de su información sensible en todo momento.
2	¿Cuenta con sistemas de protección para las aplicaciones alojadas o expuestas en la nube?. Ej.: (Web Aplicación Firewall – WAF) ¿cuáles?	a) Sib) No	A	Nosotros protegemos nuestras aplicaciones alojadas en Microsoft Azure utilizando la completa suite de seguridad de Microsoft. Empleamos herramientas como WAF, Firewalls, Sentinel, Defender for Cloud y Defender for Endpoint. Esto nos asegura una defensa robusta y multicapa contra las ciberamenazas.
3	¿Cuenta con informes de auditorías realizados a su infraestructura tecnológica y a los procesos de gestión de ciberseguridad y seguridad de la información?	a) Sib) No	A	Nuestra gestión de seguridad es auditada continuamente. Disponemos de informes del SGSI, confirmando nuestros procesos. Adicionalmente, estamos certificados ISO 27001 y realizamos pruebas de penetración externas semestralmente para nuestra infraestructura. Adjunto: - NO-SI-16- Auditoría del SGSI_v2.1_2024-11-27.pdf - NO-SI-13 Gestión de Vulnerabilidades y Parches_v2.1_2024-08-09.pdf
4	¿Qué mecanismos de autenticación utiliza para el ingreso de los usuarios a los servicios y sistemas que gestionan o procesan información de Bam?	Abierta o no aplica		aplicaciones, soportamos SSO mediante Open ID Connect, SAML 2.0 y OAuth 2.0 Bearer Token. Adicionalmente, implementamos autenticación multifactor (MFA): Microsoft Authenticator para nuestro personal y
5	¿Cuenta con políticas y medidas de seguridad para gestionar los riesgos del uso de dispositivos móviles? En caso afirmativo, mencione las políticas y medidas de control implementadas para los accesos remotos y la realización de trabajo en casa o teletrabajo.	a) Sib) No	A	Gestionamos los riesgos de dispositivos móviles con configuraciones de seguridad, gestión de aplicaciones y capacidad de borrado remoto. Para el teletrabajo y accesos remotos, aseguramos configuraciones seguras, control centralizado del hardware provisto y seguridad física del entorno. Además, exigimos cifrado, autenticación, antivirus y parches en los equipos, limitando los accesos por criticidad y rol, con autenticación robusta. Adjunto: - NO-SI-26- Seguridad en Dispositivos Móviles_v1.1_02-05-2025.pdf, - NO-TI-02- Teletrabajo_V2.1_2025-05-15.pdf, - NO-TI-01- Uso de Recursos Informáticos_v2.1.docx.pdf.
6	¿Cuenta con una política de escritorio limpio y grabación de llamadas o pantallas?. En caso afirmativo mencione la políticas y medidas de control implementadas.	a) Sib) No	A	Contamos con una "Norma de Escritorio y Pantallas Limpias" que busca evitar accesos no autorizados a la información. Implementamos controles como el bloqueo de pantallas y la responsabilidad del colaborador, con monitoreo de cumplimiento. Adjunto: NO-SI-06- Escritorio y Pantallas Limpias_v2.1_2024-11-27.pdf
7	¿Cuenta con lineamientos o procedimientos definidos para evitar la fuga de información a través de medios removibles (discos magnéticos, USB y/o dispositivos de almacenamiento extraíbles) y con que periodicidad verifica el cumplimiento de dichos lineamientos o procedimientos?	a) Sib) No	A	Prohibimos el uso de dispositivos de almacenamiento externo y bloqueamos los puertos de nuestros equipos para prevenir la fuga de información. Adjunto: - NO-SI-26- Seguridad en Dispositivos Móviles_v1.1_02-05-2025.pdf, - NO-TI-02- Teletrabajo_V2.1_2025-05-15.pdf, - NO-TI-01- Uso de Recursos Informáticos_v2.1.docx.pdf.
8	¿La información compartida por el Banco se encuentra encriptada?	a) Sib) No	A	Nuestra plataforma aplica cifrado de extremo a extremo para datos en tránsito y asegura el cifrado de datos en reposo, garantizando su máxima confidencialidad. Adjunto: NO-SI-20 Cifrado de la Información_v1.1_2024-07-10.pdf
9	¿De qué manera se distribuye la información a los participantes del proceso?	Abierta o no aplica	No aplica	La gestión de la información se realiza enteramente en el aplicativo. Se distribuye en función de los procesos establecidos durante la implementación y de acuerdo a los roles y perfiles de usuario establecidos para su gestión.
10	¿Cuál es el método para asignar la información a los participantes del proceso?	Abierta o no aplica		Mediante roles y perfiles de usuarios establecidos durante la implementación.
11	A que tipo de información tendrá acceso: publica, interna, confidencial?	a) Publicab) Internac) Confidencial	C	Durante la implementación se establece con el banco la información a gestionar en el aplicativo. Intiza considera y gestiona como Confidencial toda la información de sus clientes.
12	Cuantos empleados requieran acceso a la información de Bam?	Abierta o no aplica		Ningún empleado de Intiza tiene acceso persistente a los datos de nuestros clientes, incluyendo los de Bam. El acceso es siempre temporal, realizado desde la aplicación y estrictamente por personal autorizado ante la necesidad de soporte. A nivel de infraestructura, solo nuestro CTO posee acceso administrativo cuando es estrictamente necesario para garantizar la operación.
CATEGORÍA: Continuidad del Negocio				

1	¿La Organización cuenta con un Plan de Continuidad del Negocio documentado y aprobado por la alta dirección? De ser así, ¿ha verificado el Plan en el último año?	a) Si b) No	A	Contamos con un Plan de Continuidad de Procesamiento de Datos documentado y aprobado por la alta dirección para garantizar la continuidad del negocio. Adjunto: PO-TI-01- Continuidad de Procesamiento de Datos_v2.1_2024-11-25.pdf
2	¿Cuenta con estrategias de continuidad de negocio y recuperación ante desastres, para responder y dar continuidad a la prestación de sus servicios en caso de interrupción o materialización de dichos eventos? Detalle cuáles son las estrategias.	a) No tiene b) Se tienen con estrategias definidas y documentadas	C	Nuestras estrategias incluyen planes documentados para el restablecimiento de operaciones críticas y procedimientos de emergencia y recuperación. Estos planes son revisados y actualizados periódicamente ante cambios, y probados exhaustivamente con simulaciones y recuperación en sitios alternativos. Así, garantizamos una respuesta asertiva y la continuidad del negocio, minimizando impactos. Adjunto: PO-TI-01- Continuidad de Procesamiento de Datos_v2.1_2024-11-25.pdf
3	¿Las estrategias y/o planes de contingencia cubren los frentes de: empleados, procesos, infraestructura y tecnología?	a) No tiene b) Tiene estrategias en un frente c) Tiene estrategias en todos los frentes	D	Cumplimos con una cobertura integral en nuestros planes de continuidad del procesamiento. Estos consideran la instrucción adecuada de nuestro personal, los procesos críticos del negocio, así como nuestra infraestructura y sistemas tecnológicos, asegurando la resiliencia operativa. Adjunto: PO-TI-01- Continuidad de Procesamiento de Datos_v2.1_2024-11-25.pdf
4	¿Ejecuta pruebas en el año sobre sus estrategias de continuidad de los diferentes frentes?	a) Si b) No	A	Nuestros planes son probados al menos una vez al año, así como los servicios de proveedores externos, para garantizar su actualización y funcionalidad en situaciones reales. Adjunto: PO-TI-01- Continuidad de Procesamiento de Datos_v2.1_2024-11-25.pdf
5	¿Cuál fue el porcentaje de pruebas exitosas sobre sus estrategias de continuidad que ejecutó en el año? Indique la cantidad total de pruebas programadas.	a) No aplica b) Entre 10% y 40% c) Entre 41% y 80% d) Más del 80%	D	El 100% de las pruebas de planes resultaron exitosas.
6	¿Tiene su organización un esquema de gestión de crisis para la recuperación del servicio que presta al banco? Detállelas.	a) No tiene b) Se cuentan con un esquema de gestión de crisis	B	Adjunto: PO-TI-01- Continuidad de Procesamiento de Datos_v2.1_2024-11-25.pdf
7	¿Cuáles son los tiempos de recuperación que presenta el servicio ofrecido, ante una interrupción del mismo? Detállelos.	a) No tiene b) Mayor de 12 horas c) Entre 4.5 y 12 horas d) Menor de 4.5 horas	C	El tiempo estimado de recuperación es de 8 hs.
CATEGORÍA: Mantenimiento e Instalación				
1	¿Existe capacitación continua a empleados que garantice el conocimiento requerido para la prestación del servicio?	a) No se tiene b) Se realizan capacitaciones internas al inicio de cada año	C	Contamos con mecanismos para que nuestro personal reciba actualizaciones regulares en políticas y procedimientos, relevantes a su función. Informamos periódicamente sobre aspectos de seguridad y revisamos anualmente el nivel de conocimiento, asegurando la prestación del servicio.
2	¿Le solicita certificaciones específicas a los colaboradores quienes están a cargo de la prestación del servicio a Bam? Si su respuesta es afirmativa, detalle cuales.	a) No se tiene b) Se solicita al inicio de relación con el colaborador	B	Adjunto: NO-RH-01 Contratación de Recursos Humanos_v2.1_2025-04-30.pdf
3	¿Los materiales y/o herramientas utilizadas para realizar el mantenimiento a los activos propiedad del banco, cuentan con certificaciones y fichas técnicas que garanticen la calidad requerida para ejecutar el trabajo?	a) No se tiene b) Se buscan las opciones con mejor precio en el mercado referido		No aplica.
4	¿Los suministros proporcionados al banco cuentan con certificados de garantía, pruebas de calidad y/o fichas técnicas para su correcto funcionamiento?	a) No aplica b) No se tienen c) Se buscan las opciones con mejor precio	A	No aplica.
5	¿Cuenta con un sistema o procedimiento para notificar la llegada de sus colaboradores a las instalaciones de Bam?	a) No se tiene b) Se notifica al cliente por medio de llamada el día y hora que llegará		No aplica. Nuestro personal no requiere acceso a las instalaciones del cliente para realizar su trabajo.
6	¿Posee estrategias de continuidad que permitan cumplir los plazos definidos para la implementación de proyectos?	a) No aplica b) No se tiene c) Se definen los plazos entre al menos 15 días	C	Esto solo aplica para la etapa de configuración inicial de Intiza. Una vez operativo la administración será de personal de Bam quienes podrán hacer ajustes o cambios a la configuración o solicitar soporte específico para hacerlo.
7	Derivado a fallas del sistema o equipo instalado ¿cuenta con tiempos definidos para la atención de los problemas?	a) No Aplica b) No se tienen c) Se deja la trazabilidad del evento	E	Contamos con tiempos de respuesta definidos para la atención de problemas derivados de fallas. Estos se clasifican por criticidad, según sea Alta, Media o Baja. Adjunto: SLA Intiza - Acuerdo de Nivel de Servicio.png
8	¿Cómo garantiza brindar el mantenimiento y actualización o cambio oportuno a los sistemas y/o equipos instalados en el Banco?	a) No Aplica b) No se tienen c) Se cuenta con un programa de mantenimiento	A	No aplica. Es un sistema SaaS, no hay sistemas ni equipos instalados en el cliente.
9	Una vez finalizada la instalación y/o mantenimiento del equipo o sistema, ¿cómo garantiza a su cliente la correcta funcionalidad y utilidad de los mismos?	a) No se tiene b) El proveedor ejecuta pruebas y se envía un correo de notificación		Nosotros garantizamos el mantenimiento y actualización del software mediante nuestra Norma de Gestión de Cambios, que incluye planificación, análisis de riesgos y pruebas en ambientes dedicados. Nuestra Norma de Gestión de Vulnerabilidades y Parches asegura la aplicación oportuna de parches críticos por personal idóneo. Realizamos pruebas previas, validamos rollback y mantenemos los sistemas actualizados a un nivel n-3, asegurando su estabilidad y seguridad. Adjunto: - NO-TI-04 Gestión de Cambios_v2.2_2025-10-28.pdf, - NO-SI-13 Gestión de Vulnerabilidades y Parches_v2.1_2024-08-09.pdf
CATEGORÍA: Accesos a Servidores o Aplicativos				
1	¿Qué tipo de acceso se le debe brindar a los aplicativos de Bam para ejecutar el servicio por contratar?	a) Administrador b) Modificador c) Visualizador		No aplica. Intiza accede a los aplicativos de Bam.
2	¿La Organización tiene un proceso implementado para la revocación de permisos en sistemas de información cuando el personal (empleado, proveedor) finalice una actividad, cambie de rol o cese el contrato? Especificar su respuesta en la columna "Detalle"	a) Si b) No	A	Los accesos se deshabilitan el mismo día de la desvinculación del colaborador, con revisiones automáticas cada hora. Para terceros, el acceso es controlado por el periodo definido en su contrato. Adjunto: NO-SI-02- Gestión de Cuentas de Usuarios_v2.1.docx.pdf
3	¿Qué mecanismos de autenticación utiliza para el ingreso de los usuarios a los equipos que procesan información?	Abierta o no aplica		El acceso se realiza con usuario y contraseña. Además nuestra plataforma soporta SSO (OIDC, SAML, OAuth) y ofrece Autenticación Multifactor para IDs de usuario final, mediante código enviado a su email.
4	¿Bajo qué esquema o modalidad de trabajo laboran sus colaboradores?	a) Híbrido b) Presencial	A	
5	¿El proveedor va a requerir conexión física o lógica (a través de internet, acceso remoto (VPNs), u otros) al datacenter, sistemas centrales o core del Banco como I-Series, ATMs, Servidores o sistemas declarados como SOX y BIA?	a) Si b) No	B	
6	Cuando es necesario trasladar paquetes de datos ¿se utilizan protocolos de transferencia segura? Ej. FTPS. Especificar cuales.	a) Si b) No	A	Nuestra plataforma emplea cifrado de extremo a extremo para todos los paquetes de datos en tránsito, asegurando la máxima confidencialidad y protección contra interceptaciones malintencionadas. Adjunto: NO-SI-20 Cifrado de la Información_v1.1_2024-07-10.pdf
7	¿Realizará mantenimientos a bases de datos o registros de Bam que tengan implicación o afectación en los reportes financiero?	a) Si b) No	B	
8	¿El proveedor administrará, parametrizará y/o realizará mantenimientos a la infraestructura o plataformas de tecnología llegando a tener una afectación contable o a los reportes financieros de Bam?	a) Si b) No	B	
CATEGORÍA: Desarrollo y soporte de Software				
1	¿El proveedor tiene, o está en proceso de obtener una certificación en algún estándar de seguridad de la información, como la ISO 27001, ISO 27017 (nube), SOC2, NIST o ante un ente regulador? En caso afirmativo detalle cuales.	a) Si b) No	A	Estamos certificados en ISO/IEC 27001:2022, lo cual demuestra nuestro firme compromiso con la seguridad de la información. Nuestra certificación, válida hasta 2028-07-11, abarca la implementación, hosting y soporte de nuestras soluciones en la nube para el sector financiero. Adjunto: Certificados 27001_2025.pdf

2	¿Cuenta con ambientes de desarrollo seguro, pruebas y producción de los sistemas de información o aplicaciones?	a) Sí b) No	A	En INTIZA cumplimos con la estricta separación de ambientes de Desarrollo, Pruebas y Producción para todos nuestros sistemas y aplicaciones. Integramos la seguridad desde el inicio del ciclo de vida del software, aplicando prácticas de desarrollo seguro y controles previos a la puesta en producción. Adicionalmente, los datos de prueba se protegen rigurosamente utilizando información ficticia o anonimizada, garantizando la seguridad de su información. Adjunto: NO-SI-09 - Gestión de ambientes_2024-07-10_v1.2.pdf
3	¿Los ambientes no productivos se encuentran separados, lógica o físicamente, del ambiente productivo para reducir los riesgos de acceso o cambios no autorizados en producción?	a) Sí b) No	A	Nuestra plataforma cumple con la separación de ambientes no productivos del ambiente productivo, tanto lógica como físicamente. Esto se logra a través de ambientes diferenciados, controles de acceso y segregación de directorios o librerías, según lo establece nuestra Norma de Gestión de Ambientes. Adjunto: NO-SI-09 - Gestión de ambientes_2024-07-10_v1.2.pdf
4	¿Realiza pruebas de seguridad (Ethical Hacking) sobre los sistemas de información antes de pasar a producción?	a) Sí b) No	A	Realizamos pruebas de seguridad exhaustivas, incluyendo Ethical Hacking y pruebas de vulnerabilidad en nuestras aplicaciones. Integramos la seguridad desde el inicio del ciclo de desarrollo, realizando pruebas dinámicas, análisis estáticos de código y revisiones humanas antes de pasar a producción.
5	¿Tiene un esquema de control definido para el acceso al código fuente en los diferentes ambientes?	a) Sí b) No	A	Utilizamos software de control de código fuente para proteger nuestros activos.
6	¿El proveedor cumplirá funciones de fábrica de Desarrollo de Software, incluyendo certificación y producción y/o tendrá acceso al código fuente de las aplicaciones y bases de datos que respalden procesos críticos para la operación de Bam?	a) Sí b) No	B	
7	¿Posee controles de doble validación de los cambios o modificaciones realizados a los aplicativos de Bam previo a salir a producción?	a) No tiene b) El desarrollador quien realiza los cambios es e	D	Esto solo aplica a cambios en el aplicativo de Intiza. No realizamos cambios o modificaciones en aplicativos o sistemas de Bam.
8	¿Existe capacitación continua a empleados que garantice la exactitud y completitud del modelo?	a) No se tiene b) se realizan capacitaciones internas al inicio	C	
9	¿Le solicita certificaciones específicas a los desarrolladores quienes están a cargo de la implementación del modelo? Si su respuesta es afirmativa, detalle cuales.	a) No se tiene b) se solicita al inicio de relación con el colab	B	